Dossier de Recherche Préparatoire : Sécurisation de Lidl Collect

Ce document retrace la phase d'investigation, d'analyse et de benchmark qui a permis de définir les standards de sécurité de l'application. Il démontre la cohérence entre les recherches théoriques et la mise en œuvre technique finale.

1. BENCHMARK : ANALYSE DES STANDARDS ET DE L'EXISTANT

Avant de définir notre propre politique, j'ai effectué un benchmark basé sur deux axes : les recommandations des autorités et l'analyse des pratiques réelles de l'enseigne.

A. Analyse du Référentiel Interne Lidl

L'analyse des documents de protection des données de **Lidl (version novembre 2025)** a permis d'aligner le projet sur les standards du groupe :

- **Droit à l'oubli :** Intégration des durées de conservation (ex : suppression des comptes après 3 ans d'inactivité).
- **Expérience Lidl Plus :** Observation des exigences de complexité des mots de passe existants pour garantir une cohérence de sécurité entre les services.

B. Veille comparative sur sites tiers

En observant les pratiques de plateformes leaders (type Snowflake, Stripe ou Checkout.com), les mécanismes de défense suivants ont été identifiés comme indispensables :

- **Limitation des tentatives :** Mise en place d'un verrouillage temporaire après 5 essais infructueux pour stopper les attaques par force brute (principe de la "serrure de sécurité").
- **Vérification de l'identité :** Utilisation du "Double Opt-in" (confirmation par email) pour valider l'authenticité de l'utilisateur.

2. ANALYSE DES FACTEURS D'AUTHENTIFICATION (RÉFÉRENTIEL ANSSI)

L'étude des preuves d'identité a permis de sélectionner les méthodes les plus robustes selon les trois catégories définies par l'ANSSI :

1. **Facteur de connaissance :** Ce que l'utilisateur sait (ex : Mot de passe complexe).
2. **Facteur de possession :** Ce que l'utilisateur détient (ex : Smartphone pour recevoir un code OTP).
3. **Facteur d'inhérence :** Ce que l'utilisateur est (ex : Empreinte digitale ou reconnaissance faciale via smartphone).

Décision stratégique : L'authentification multifacteur (**MFA**), combinant au moins deux de ces facteurs, a été rendue obligatoire pour tous les accès sensibles (Administrateurs et Opérateurs).

3. TABLEAU DE SYNTHÈSE : DE LA RECHERCHE AUX RÉSULTATS FINAUX

Ce tableau récapitule la traduction des recherches théoriques en solutions concrètes dans la politique d'authentification et les spécifications de paiement.

DOMAINES	RÉSULTATS DES RECHERCHES & SOURCES	APPLICATION DANS LE PROJET FINAL
Mots de Passe	Recommandations de la CNIL sur la longueur et la complexité.	**Politique :** Minimum 12 caractères complexes + hachage **Bcrypt**.
Sessions	Standards OWASP sur la gestion des jetons numériques.	**Politique :** Utilisation de **JWT** (Access/Refresh) avec rôles intégrés.
Confidentialité	Principes de "Salage et Hachage" pour l'illisibilité des données.	**Politique :** Aucun mot de passe stocké en clair (transformation irréversible).
Sécurité Web	Sécurisation des cookies (HttpOnly/Secure).	**Politique :** Jetons stockés en cookies protégés contre les scripts malveillants.
Paiement (Données)	Analyse de la **Tokenisation** (IBM / Stripe).	**Théorie Paiement :** Remplacement des n° de carte par des jetons sans valeur.
Paiement (Flux)	Protocoles TLS et isolation via iFrames.	**Théorie Paiement :** Tunnel chiffré **HTTPS** et saisie bancaire hors de notre code.
Fraude	Obligations DSP2 et détection intelligente.	**Théorie Paiement :** Activation du **3D Secure 2** et analyse des comportements suspects.

4. SOURCES ET RÉFÉRENCES

Pour garantir la conformité de ces choix, les ressources officielles suivantes ont été consultées :

- **CNIL : Recommandations pour maîtriser la sécurité des mots de passe**
- **ANSSI : Guide de l'authentification multifacteur et des mots de passe (PDF)**
- **OWASP : Authentication Cheat Sheet - Standards de sécurité applicative**
- **Lidl :** Documentation interne sur la protection des données (Consultée en version 2025).